

메디컬링크 EMR 클라우드 전환

의료정보 보안 검토서

문서번호	SH-2026-SEC-011
작성일	2027년 1월 8일
상위 문서	SH-2026-SOW-011 과업지시서 3.3 (EM-03)
검토	서하의료원 정보보호책임자, 진료정보관리과

1. 검토 범위와 전제

본 검토서는 클라우드로 옮긴 뒤의 진료기록 보호 조치를 정한다. 대상은 EMR 이 다루는 환자 인적 사항·진료내용·처방·검사 결과와 그 접근기록이다. 의료영상(PACS)은 이관 대상이 아니므로 접근통제 연계 구간만 다룬다.

- 클라우드는 클라우드 보안인증을 받은 국내 리전 IaaS 를 전제로 한다.
- 인터넷 구간을 열지 않으므로 외부 위협보다 내부자 오·남용을 주된 위협으로 본다.
- 본 검토서의 통제는 전환일부터 적용하며, 병행운영 기간에도 동일하게 적용한다.

2. 개인정보 및 진료기록 보호

2.1 보존 기간

대상	보존 기간	근거
진료기록부	10년	의료법 시행규칙
수술기록·검사 소견	10년	의료법 시행규칙
처방전	2년	의료법 시행규칙
접근기록(감사로그)	5년	원내 정보보호 지침
가명처리 데이터셋 반출 대장	5년	원내 정보보호 지침
교육 이수 명부	3년	원내 정보보호 지침

접근기록은 5년간 보존하며 보존 기간 중에는 삭제·변경할 수 없다. 보존 기간이 지난 접근기록은 분기 단위로 일괄 파기하고 파기 대장에 남긴다.

2.2 암호화

구간	방식	비고
저장 데이터	AES-256 블록 암호화	테이블스페이스 단위
전송 구간	TLS 1.3	하위 버전 협상 차단
백업 매체	AES-256	복호화 키는 별도 보관
주민등록번호	일방향 해시 + 솔트	평문 저장 금지
키 관리	전용 키 관리 서비스	키 교체 주기는 180일

키 교체 주기는 180일이며, 교체 이력은 정보보호책임자가 반기마다 확인한다. 운영자는 키를 직접 조회할 수 없고 키 사용 권한만 부여받는다.

3. 접근통제

3.1 역할별 열람 범위

역할	열람 범위	승인	예외
진료의	본인과 진료관계가 있는 환자	자동	응급 시 긴급열람
간호사	소속 병동 재원 환자	병동 수간호사	당직 교대 시 임시 부여
의료기사	본인에게 의뢰된 검사 건	자동	없음
약사	처방 검토 대상 건	자동	없음
원무·행정	인적사항과 수납 정보 (진료내용 제외)	자동	없음
연구자	가명처리 데이터셋만	기관생명윤리위원회 승인	없음
시스템 운영자	데이터 직접 조회 금지, 승인된 쿼리만 실행	정보보호책임자	없음

진료관계 없는 조회는 사유 입력 후 열람이 가능하며, 사유 미입력 조회는 차단한다. 입력된 사유는 접근기록에 함께 남기고 진료정보관리과가 월 단위로 표본 점검한다.

3.2 긴급열람

응급 상황에서 권한 밖 기록을 열람해야 할 때는 긴급열람 절차를 쓴다. 열람은 즉시 허용하되 사후에 정당성을 확인한다.

- 긴급열람 시 사유 코드를 반드시 고른다. 자유 입력만으로는 진행되지 않는다.
- 긴급열람 건은 2시간 내 사후 승인을 받는다. 승인자는 해당 진료과장이다.
- 사후 승인이 없으면 익일 정보보호책임자에게 보고한다.
- 긴급열람 건은 월간 보안 점검 보고서에 전건 목록으로 심는다.

3.3 계정 관리

- 퇴직·전보 시 계정 권한은 당일 회수한다.

- 미사용 90일이 지난 계정은 자동 잠금한다.
- 관리자 계정은 다중 인증을 적용하고 공용 계정을 두지 않는다.
- 실습·교육 계정은 교육 종료 후 7일 내 삭제한다.
- 권한 재검토는 반기 1회 전 계정을 대상으로 한다.

4. 가명처리

연구·통계 목적으로 진료 데이터를 쓸 때는 가명처리한 데이터셋만 반출한다. 원본 데이터베이스에 대한 연구자 접근은 어떤 경우에도 허용하지 않는다.

4.1 판정 기준

- 동질 집합 크기는 k-익명성 $k=5$ 이상이어야 한다.
- 민감 속성은 l-다양성 $l=2$ 이상을 만족해야 한다.
- 재식별 위험도 0.04 이하일 때만 반출을 승인한다.
- 기준을 만족하지 못하면 일반화 수준을 한 단계 올려 다시 산정한다.

4.2 항목별 처리 기법

항목	기법	비고
주민등록번호	삭제	대체 식별자 부여
성명	삭제	—
생년월일	출생연도만 남기고 5세 구간으로 범주화	90세 이상은 한 구간
주소	시군구까지만	읍면동 이하 삭제
진료일자	주 단위로 일반화	응급 건은 월 단위
희귀질환 상병코드	상위 분류로 대체	국내 100명 미만 질환
의료진 식별자	가명 코드로 대체	매 반출마다 재생성

4.3 반출 절차

반출은 네 단계를 거친다. 단계를 건너뛴 반출은 무효로 보고 회수한다.

가명처리 반출 절차

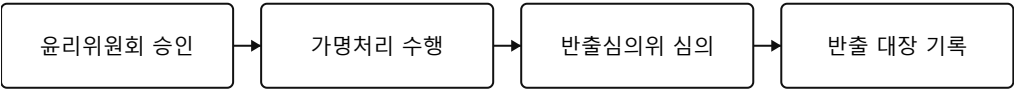


그림 1 가명처리 데이터셋 반출 4단계

- 1단계 — 기관생명윤리위원회 승인서 접수
- 2단계 — 가명처리 수행 및 판정 기준 충족 확인
- 3단계 — 반출심의위원회 심의 (월 1회, 위원 7명)
- 4단계 — 반출 대장 기록 및 수령 확인

5. 감사로그

5.1 기록 항목

항목	내용	예
누가	계정, 소속, 역할	간호사 / 8병동
언제	요청 시각 (밀리초)	2027-05-12 03:14:07.221
무엇을	환자 식별자, 기록 종류, 조회 건수	외래기록 1건
어디서	단말 식별자, 접속 구간	카트 단말 C-118
왜	사유 코드 (권한 밖 조회 시)	긴급열람 E03
결과	허용·차단 여부	허용

5.2 위변조 방지

- 접근기록은 일 1회 해시 체인으로 묶어 전일 값과 연결한다.
- 기록 저장소는 쓰기 후 변경이 불가능한 매체를 쓴다.
- 운영자는 접근기록 저장소에 삭제 권한을 갖지 않는다.
- 해시 체인 검증은 월 1회 자동 수행하고 결과를 보고한다.

5.3 이상 탐지 규칙

규칙	임계	조치
단시간 대량 조회	10분간 200건 초과	경보 발송 후 세션 차단
야간 비진료시간 조회	23시~06시 진료관계 없는 조회	익일 검토 대상 등록
직원·가족 기록 조회	전건	즉시 알림 및 사유 확인
대량 출력·내려받기	1회 50건 초과	사전 승인 없으면 차단
동일 계정 중복 접속	서로 다른 단말 3대 이상	이전 세션 종료
권한 밖 반복 시도	1시간 내 10회	계정 일시 잠금

환자 본인이 자신의 기록에 누가 접근했는지 요구하면 진료정보관리과가 접근기록을 발취해 제공한다. 처리 기한은 요구일로부터 10일이다.

6. 잔여 위험

번호	잔여 위험	현황	조치 기한
S-1	구 EMR 아카이브에 대한 접근통제가 신규 체계와 다르다	아카이브는 조회 전용, 권한 목록 미정리	2027-06-30
S-2	의료영상 게이트웨이 구간의 접근기록이 EMR 과 분리되어 있다	통합 수집 미적용	2027-07-31
S-3	교육 실습 계정의 권한이 실제 계정과 동일하다	실습 전용 권한 세트 설계 중	2027-03-01
S-4	협력업체 원격 지원 구간의 녹화가 없다	녹화 도구 도입 검토	2027-08-31